

UNIVERSITY OF SCIENCE, VNUHCM
FACULTY OF INFORMATION TECHNOLOGY



SOFTWARE TESTING

HW06 – API Testing

1. Student Information & General Information

- Name: Trần Trí Nhân
- Student ID: 23127097

Test case generation review

Pool A:

- API endpoint: POST /api/register
- Feature: FR01 - Account registration
- Audit: All test cases are VALID, except for TC14(INVALID) TC28(INCOMPLETE). TC14 is labeled as INVALID because it invents whitespace trimming requirement(no mention in README or API specification). TC28 is labeled as INCOMPLETE because the expected output is ambiguous. Since both README file and API specification do not require a maximum length for password, we must set the expected outcome as succeed.
- Correction:
 - TC14: Expect 400 Bad Request instead of 200 OK.

- TC28: Expect 200 OK.

Pool B:

- API endpoint: GET /api/cart
- Feature: FR07 - Shopping cart
- Audit: All test cases are VALID, except for TC11(INVALID), TC21(INVALID) and TC34(INVALID). TC11 is INVALID because it expects error for lowercase bearer, but bearer scheme is case-insensitive. TC21 is INVALID because it tests FR08 instead of FR07. TC34 is INVALID because leading and trailing whitespaces in header values are automatically trimmed.
- Correction:
 - Both TC11 and TC34 must expect 200 OK.
 - Remove TC21 from this suite

Pool C:

- API endpoint: POST /api/categories
- Feature: FR14 - Category management (Category CRUD)
- Audit: All test cases are VALID, except for TC31(INCOMPLETE). TC31 is INCOMPLETE because its expected outcome is non-deterministic.
- Correction: Update the expectation to strictly be " SÁCH " since the specification does not require whitespace trimming.

Test case extension

Pool A:

TC36 — Objective: email field sent as non-string type (number)

Input: {"name":"Nguyen Van A","email":12345,"password":"Password123!"}

Expected: 400 Bad Request; error message indicates invalid type for email

Covers: Schema validation — type constraint

TC37 — Objective: SQL Injection payload in password field

Input: {"name":"Nguyen Van A","email":"tc37@domain.com","password":"' OR '1'='1'"}

Expected: 400 Bad Request

Covers: SEC-05 (parameterized queries — injection safely rejected at validation layer)

TC38 — Objective: XSS/script payload in email field

Input: {"name":"Nguyen Van A","email":"<script>alert(1)</script>","password":"Password123!"}

Expected: 400 Bad Request; response returns as plain text in JSON

Covers: SEC-04 relevance at API layer

TC39 — Objective: XSS/script payload in password field

Input: {"name":"Nguyen Van A","email":"tc39@domain.com","password":"<script>alert(1)</script>"}

Expected: 400 Bad Request; response returns as plain text in JSON

Covers: SEC-04 relevance at API layer

TC40 — Objective: password is whitespace only

Input: {"name":"Nguyen Van A","email":"tc40@domain.com","password":" "}

Expected: 400 Bad Request; error message indicates password cannot be whitespace only

Covers: Domain partition

Why the AI missed these test cases

These test cases were extended based on the test cases designed by the AI but with other fields in the request body. The AI missed these test cases because it had to cover domain partitions, state transitions, security and schema validation within 35 test cases, so it could not provide all possible combinations of the body fields and the test techniques.

Test case execution:

- [GitHub repository link](#)
- [Excel report](#)
- [Bug report](#)
- List of Postman features used: workspace, collection, variable, pre-request scripts, postman cli(via CI).
- [CI/CD report](#)

Appendices

Appendix A

[AI Audit Report](#)

[AI Critique](#)

Appendix B

[Self-assessment & Test summary report](#)